Trường Đại học Công nghệ Thông tin, ĐHQG-HCM
Bộ môn An toàn Thông tin

3

Lab

Botnet

Thực hành Cơ chế hoạt động của Mã độc

Lưu hành nội bộ 2026

<Không được phép đăng tải trên internet dưới mọi hình thức>

Mọi thắc mắc đóng góp vui lòng email cho khoanh@uit.edu.vn

A. TỔNG QUAN

A.1 Mục tiêu

- Hiểu khái niệm botnet, payload, C2 server.
- Thiết lập và phân tích botnet mã nguồn mở.
- Xây dựng và sử dụng máy chủ C2 (Havoc, Sliver).
- Ghi lại và phân tích giao tiếp giữa bot và C2 qua Wireshark.
- Tích hợp worm/payload vào botnet và khai thác.
- (Nâng cao) Thực hiện bypass Windows Defender.

A.2 Thời gian thực hành

- Tại lớp 5 tiết.
- Tại nhà 7 ngày.

B. CHUẨN BỊ MÔI TRƯỜNG

- Kali Linux hoặc Ubuntu (dùng làm C2 server)
- Windows 10/11 VM (victim)
- Optional: FLARE-VM

C. THỰC HÀNH

C.1 Tìm hiểu về botnet

Trong phần này, sinh viên sẽ lựa chọn một trong các dự án botnet mã nguồn mở dưới đây (hoặc một dự án tương tự do sinh viên tự tìm kiếm), để tiến hành tìm hiểu và phân tích chi tiết:

- https://github.com/0x1CA3/Net
- https://github.com/wodxgod/PYbot
- https://github.com/TryZeroOne/Contagio
- https://github.com/Markus-Go/bonesi
- https://github.com/CirqueiraDev/KryptonC2
- https://github.com/0xbitx/DEDSEC_BOTNET

NHIỆM VỤ:

Câu 1: Tìm hiểu các khái niệm cơ bản liên quan đến botnet: định nghĩa, mục tiêu, thành phần cơ bản (bot, C2 server, payload…), và vai trò của botnet trong các cuộc tấn công mạng.

Câu 2: Phân tích chi tiết hoạt động của botnet đã chọn, bao gồm:

- Cách botnet thiết lập kết nối và duy trì liên lạc giữa bot và máy chủ C2.
- Giao thức truyền thông được sử dụng (TCP/UDP/HTTP/WebSocket…)
- Hệ điều hành hỗ trợ và yêu cầu môi trường thực thi.
- Quá trình xây dựng mạng botnet, biên dịch payload, và phương pháp triển khai bot lên máy nạn nhân.

Câu 3: Phân tích cơ chế giao tiếp của botnet bằng cách:

- Biên dịch lại mã nguồn và chạy thử nghiệm trong môi trường mô phỏng (VM).
- Sử dụng công cụ như Wireshark để bắt gói tin trao đổi giữa bot và C2.
- Ghi nhận lại các mẫu gói tin, lệnh trao đổi, thông tin xác thực (nếu có), định dạng dữ liệu.\n
- Đọc và phân tích mã nguồn của botnet để hiểu logic xử lý lệnh, mã hóa dữ liệu, hoặc kỹ thuật ẩn danh sử dụng trong quá trình giao tiếp.

C.2 Tìm hiểu về Máy chủ C2 (Command and Control Server)

Ở cấp độ nâng cao, máy chủ C2 (Command and Control) đóng vai trò trung tâm trong việc quản lý các thiết bị bị lây nhiễm (bots), tương tự như trong kiến trúc botnet, nhưng với khả năng điều khiển linh hoạt hơn và nhiều tính năng hỗ trợ hiện đại hơn như tự động hóa lệnh, tải payload, mô-đun mở rộng, giao diện điều khiển nâng cao, và tích hợp kỹ thuật tránh bị phát hiện.

Sinh viên cần lựa chọn một nền tảng máy chủ C2 phổ biến dưới đây để tiến hành nghiên cứu và thực hành:

- Cobalt Strike: https://www.cobaltstrike.com/
- Havoc: https://github.com/HavocFramework/Havoc
- Sliver https://sliver.sh/
- Empire: https://bc-security.gitbook.io/empire-wiki

- Brute Ratel: https://bruteratel.com/
- Mythic: https://github.com/its-a-feature/Mythic

NHIỆM VỤ:

Câu 4: Tìm hiểu tổng quan về hệ thống C2 đã chọn, bao gồm:
- Kiến trúc tổng thể: client-server, agent, mô-đun mở rộng.
- Các thành phần chính: listener, payload, communication handler, implant, UI console…
- Yêu cầu về hệ điều hành, ngôn ngữ lập trình, cơ sở dữ liệu.

Câu 5: Cài đặt và xây dựng máy chủ C2:
- Hướng dẫn thiết lập môi trường lab cho máy chủ C2 (Linux hoặc Docker).
- Tạo payload và deploy agent trên máy victim.
- Quan sát kết nối và điều khiển nạn nhân từ phía C2.

Câu 6: Khám phá các tính năng nâng cao của nền tảng C2:
- Tạo và tiêm shellcode hoặc module tùy chỉnh.
- Sử dụng kỹ thuật obfuscation và mã hóa payload để tránh bị phát hiện.
- Kỹ thuật domain fronting để vượt qua kiểm duyệt mạng và ngụy trang traffic.
- Theo dõi cách mã hóa giao tiếp, cơ chế xác thực giữa client – server.

Câu 7: Tích hợp Worm Payload từ lab trước:
- Tái cấu trúc mã nguồn worm cũ để đóng gói thành một payload có thể chạy dưới dạng agent/implant của hệ thống C2.
- Triển khai payload này lên máy victim từ hệ thống C2 vừa thiết lập và kiểm tra tính ổn định, khả năng tự lan truyền (nếu có).

Câu 8: Bài tập nâng cao – Bypass Windows Defender:
- Yêu cầu: Tạo payload sao cho khi victim (Windows 10/11 đã bật Defender cập nhật mới nhất) kết nối về C2, duy trì kết nối trong ít nhất 15 phút, đồng thời thực hiện tuần tự các lệnh:

```
whoami
systeminfo
ping google.com
```

- Yêu cầu báo cáo:
  - Phương pháp obfuscation/mã hóa hoặc packer được sử dụng.
  - Giải thích lý do tại sao cách thực hiện đó có thể vượt qua được Windows Defender.
  - Ghi lại toàn bộ log lệnh, phản hồi và traffic liên quan để phục vụ đánh giá.

D. YÊU CẦU

- Sinh viên tìm hiểu và thực hành theo hướng dẫn theo nhóm đã sắp xếp.
- Báo cáo kết quả chi tiết những việc (**Report**) đã thực hiện, quan sát thấy và kèm ảnh chụp màn hình kết quả (nếu có); giải thích cho quan sát (nếu có), video demo (điểm cộng) đăng tải Youtube với chế độ unlisted.

Báo cáo:

- Làm báo cáo trên file **mẫu**.
- File **.PDF**. Tập trung vào nội dung, không mô tả lý thuyết.
- Trong file báo cáo yêu cầu **ghi rõ** nhóm sinh viên thực hiện.
- Đặt tên theo định dạng: [Mã lớp]-Lab1_MSSV1-MSSV2.pdf
  Ví dụ: [NT330.K21.ANTN.1]-Lab2_1552xxxx-1552yyyy.pdf
- Nếu báo cáo có nhiều file, nén tất cả file vào file **.ZIP** với cùng tên file báo cáo.
- Nộp file báo cáo trên theo thời gian đã thống nhất tại courses.uit.edu.vn.

Đánh giá: Sinh viên hiểu và tự thực hiện được bài thực hành. Khuyến khích:

- Chuẩn bị tốt và đóng góp tích cực tại lớp.
- Có nội dung mở rộng, ứng dụng trong kịch bản phức tạp hơn, có đóng góp xây dựng bài thực hành.

Bài sao chép, trễ,... sẽ được xử lý tùy mức độ vi phạm.

-HẾT-